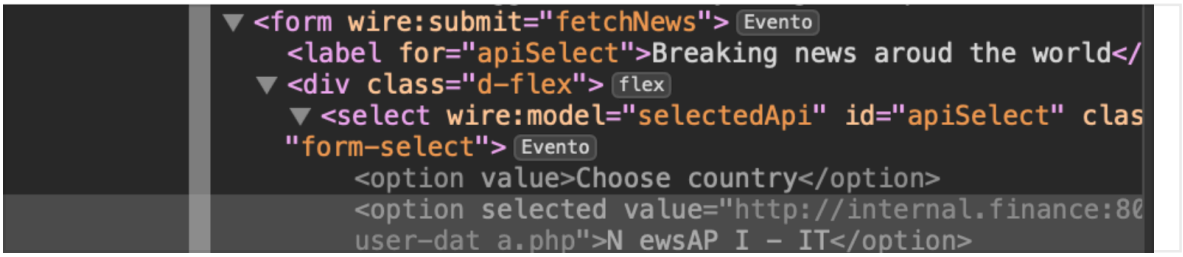
Challenge 4 – Manomissione input (funzionalità news)

Nella pagina di creazione articolo c'è un menu Get inspired. All'inizio le opzioni contenevano URL completi, modificabili da Ispeziona. Così un utente poteva far partire dal server una richiesta verso un indirizzo non previsto, ad esempio il servizio interno sulla porta 8001 e ottenere dati che non dovrebbe vedere.

Prova prima della mitigazione-

Sono entrato come writer, ho aperto la pagina crea articolo e, dal menu news, ho modificato il value di un'option puntandolo a internal.finance:8001 (user-data.php).
In Rete, nella risposta Livewire, comparivano i dati finanziari (utenti, saldi, ecc.).







Mitigazione-

Ho sistemato la funzionalità in tre punti:
-latest-news.blade.php : nel menu non ci sono più URL, solo chiavi paese (it, gb, us).
-LatestNews.php: accetta solo quelle chiavi e costruisce l'URL NewsAPI lato server (con la API key da .env / config).
-HttpService.php: le richieste verso internal.finance sono consentite solo se

l'utente è admin .
Così anche se qualcuno modifica ancora il value nel browser, la richiesta non restituisce i dati sensibili.



Livewire > LatestNews.php

```php
<?php

namespace App\Livewire;

use Livewire\Component;
use App\Services\HttpService;

class LatestNews extends Component
{
    public $selectedApi;
    public $news;
    protected $httpService;

    public function __construct()
    {
        $this->httpService = app(HttpService::class);
    }

    public function fetchNews()
    {
        $allowedCountries = ['it', 'gb', 'us'];

        if (!in_array($this->selectedApi, $allowedCountries, true)) {
            $this->news = ['error' => 'Selezione non valida'];
            return;
        }

        $apiKey = config('services.newsapi.api_key');
        $url = "https://newsapi.org/v2/top-headlines?country={$this->selectedApi}&apiKey={$apiKey}";

        $response = $this->httpService->getRequest($url);
        $this->news = json_decode($response, true);

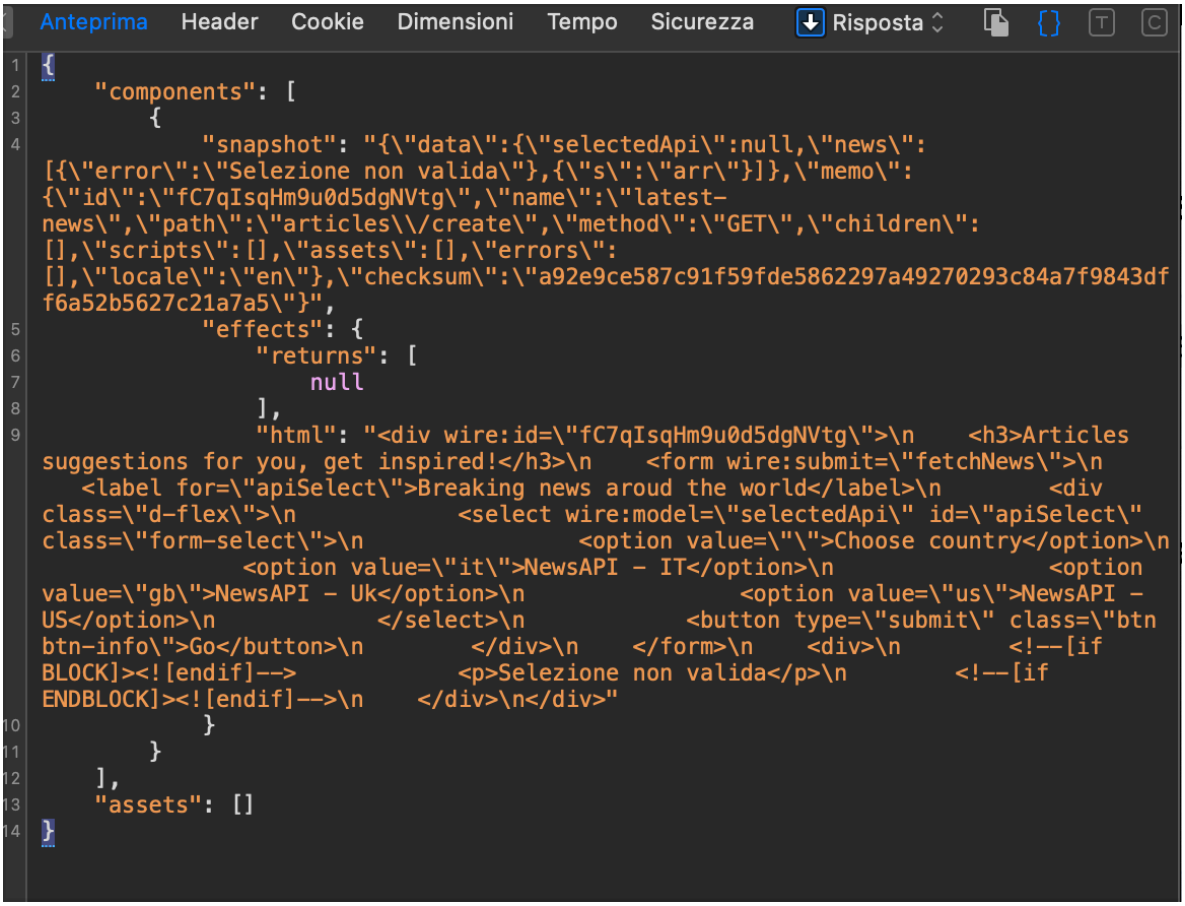
        if (!is_array($this->news)) {
            $this->news = ['error' => 'Impossibile recuperare le news'];
        }
    }

    public function render()
    {
        return view('livewire.latest-news');
```



Prova dopo la mitigazione-

Ho rifatto la stessa prova come writer (modifica del value verso finance + Go). In Rete la risposta non conteneva più i dati finanziari, ma un errore che indicava che la selezione non era valida.




```
{
    "components": [
        {
            "snapshot": "{\"data\":{\"selectedApi\":null,\"news\":
[{\"error\":\"Selezione non valida\"},{\"s\":\"arr\"}]},\"memo\":
{\"id\":\"fC7qIsqHm9u0d5dgNVtg\",\"name\":\"latest-
news\",\"path\":\"articles\\/create\",\"method\":\"GET\",\"children\":
[],\"scripts\":[],\"assets\":[],\"errors\":
[],\"locale\":\"en\"},\"checksum\":\"a92e9ce587c91f59fde5862297a49270293c84a7f9843df
f6a52b5627c21a7a5\"}",
            "effects": {
                "returns": [
                    null
                ],
                "html": "<div wire:id=\"fC7qIsqHm9u0d5dgNVtg\">\n    <h3>Articles
suggestions for you, get inspired!</h3>\n    <form wire:submit=\"fetchNews\">\n
   <label for=\"apiSelect\">Breaking news aroud the world</label>\n        <div
class=\"d-flex\">\n            <select wire:model=\"selectedApi\" id=\"apiSelect\"
class=\"form-select\">\n                <option value=\"\">Choose country</option>\n
                <option value=\"it\">NewsAPI - IT</option>\n                <option
value=\"gb\">NewsAPI - Uk</option>\n                <option value=\"us\">NewsAPI -
US</option>\n            </select>\n            <button type=\"submit\" class=\"btn
btn-info\">Go</button>\n        </div>\n    </form>\n    <div>\n        <!--[if
BLOCK]><![endif]-->            <p>Selezione non valida</p>\n        <!--[if
ENDBLOCK]><![endif]-->\n    </div>\n</div>"
            }
        }
    ],
    "assets": []
}
```